

SACI: SIEM-CTI Görünürlük Kanıtlarının Graf Destekli Ölçümü

İsmet Arslan

Bilgisayar Mühendisliği Anabilim Dalı, Lisansüstü Eğitim Enstitüsü

Karamanoğlu Mehmetbey Üniversitesi

Karaman, Türkiye

ORCID: 0009-0005-0274-7989

Abstract—Bir güvenlik bilgi ve olay yönetimi (SIEM) sisteminde çok sayıda alarm bulunması, kritik varlıkların beklenen loglarla izlendiğini veya bu logların çalışan tespitler, MITRE ATT&CK teknikleri ve tehdit istihbaratıyla izlenebilir biçimde bağlandığını tek başına göstermez. Bu çalışma, sabit ve sürümlenmiş bir kapsam içinde bu ilişkilerin kapanışını ölçen Security Analytics Coverage Index (SACI) yaklaşımını sunmaktadır. SACI; kritik varlık ağırlıklı log kapsamı, etkin kontrol/alarm kapsamı, seçili ATT&CK teknik kapsamı, CTI entegrasyon iş akışı ve koşum tazeliğini ayrı bileşenler olarak hesaplar. Tiplenmiş kanıt grafi skorun dayandığı varlık-log-kontrol-kural-teknik-IOC zincirini gösterirken, bağımsız bütünlük kapısı bozuk düğüm veya eşleme içeren çıktıları geçersiz sayar. Yöntem altı varlıklı Wazuh-MISP laboratuvarında uygulanmıştır. Kanonik koşumda tanımlı log, kontrol, teknik ve CTI beklentileri kapanmış; seçili telemetri, CTI ve tazelik kayıpları ilgili bileşenlerde beklenen düşüşleri üretmiştir. Sonuçlar SACI'nin güvenlik başarısını değil, tanımlı kapsam içindeki kanıt tamlığını ve bu kanıtın denetlenebilirliğini ölçtüğünü göstermektedir.

Index Terms—SACI, SIEM, Wazuh, MITRE ATT&CK, MISP, tespit kapsamı, kanıt grafi, bütünlük doğrulaması

Abstract

A large number of alerts in a security information and event management (SIEM) system does not by itself demonstrate that critical assets are monitored through the expected logs or that those logs are traceably connected to active detections, MITRE ATT&CK techniques, and threat intelligence. This study presents the Security Analytics Coverage Index (SACI), which measures the closure of these relations within a fixed and versioned scope. SACI separately calculates criticality-weighted log coverage, enabled control and alert coverage, scoped ATT&CK technique coverage, CTI integration workflow closure, and run-level freshness. A typed evidence graph exposes the asset-log-control-rule-technique-IOC chains behind the scores, while an independent integrity gate rejects outputs with invalid nodes or mappings. The method was applied to a six-asset Wazuh-MISP laboratory. The canonical run closed the declared expectations; selected telemetry, CTI, and freshness losses produced the expected component-level decreases. SACI therefore measures evidence completeness and auditability within a declared scope rather than security effectiveness.

Keywords—SACI, SIEM, Wazuh, MITRE ATT&CK, MISP, detection coverage, evidence graph, integrity validation.

I. GİRİŞ

Güvenlik operasyon merkezleri (SOC), farklı işletim sistemleri, ağ cihazları ve güvenlik ürünlerinden gelen olayları SIEM üzerinde bir araya getirir. Buna rağmen logların sisteme ulaşması ile kullanılabilir güvenlik görünürlüğü aynı şey

değildir. Bir varlıktan veri geliyor olabilir ancak veri eski olabilir, ilgili tespit kuralı hiç çalışmamış olabilir veya alarmın hangi ATT&CK tekniği ve tehdit istihbaratı kaydıyla ilişkili olduğu gösterilemeyebilir. SOC çalışmalarında araç, süreç ve insan boyutlarının birlikte değerlendirilmesi gerektiği uzun süredir vurgulanmaktadır [1]–[3]. Açık kaynak SIEM'lere yönelik güncel deneyler de ürünlerin toplama ve performans özelliklerini karşılaştırmakla birlikte, kurumun kendi kapsamındaki kanıt zincirinin ne ölçüde kapandığını ayrı bir problem olarak bırakmaktadır [4].

ATT&CK tabanlı teknik kapsam bu boşluğu kısmen görünür hâle getirir. DeTT&CT veri kaynağı kalitesi, görünürlük ve tespit kapsamını puanlamaya yönelik güçlü bir operasyonel araçtır [5]. Chamkar ve arkadaşları cihazlardan üretilen olayları ATT&CK ile eşleyerek SOC use-case kapsamı ve boşluk analizi önermiştir [6]. Ancak ATT&CK etiketi bulunan bir kuralın varlığı tek başına gerçek bir olay üzerinde çalışan bir tespiti kanıtlamaz. Virkud ve arkadaşları da farklı ürünlerdeki ATT&CK kapsamının düşük önem düzeyli kurallarla şişebildiğini ve aynı tehdit davranışının tutarsız tekniklerle etiketlenebildiğini göstermiştir [7]. Bu nedenle SACI, ATT&CK kapsamını bir güvenlik başarısı olarak değil, önceden tanımlı teknik kümesindeki kanıt kapanışı olarak ele alır.

Literatürdeki diğer çizgiler probleme farklı düzeylerden yaklaşır. SOC-CMM insan, süreç, teknoloji ve hizmetler üzerinden SOC olgunluğunu değerlendirir [8]. KRYSTAL gibi bilgi grafi çalışmaları ise audit verisi, tehdit istihbaratı ve tespit yöntemlerini saldırı keşfi ve senaryo yeniden oluşturma için birleştirir [9]. CTI araştırmaları paylaşım modellerini ve besleme kalitesini inceler [10], [11]. Buna karşılık sabit bir kurumsal kapsam içinde varlık, log kaynağı, etkin kontrol, SIEM kuralı, ATT&CK tekniği ve CTI iş akışını aynı denetlenebilir zincirde tutan; pay ve paydaları yayımlayan ve yapısal olarak bozuk bir çıktı yüksek puan olsa dahi yayını durduran uygulamalı ölçüm protokolleri sınırlıdır.

Bu çalışma bu dar boşluğa odaklanmaktadır. SACI'nin amacı yeni bir risk formülü geliştirmek değil, beş soruya açık yanıt üretmektir: Beklenen loglar geliyor mu? Etkin kontroller gerçekten kanıt veya alarm üretti mi? Kapsam içindeki teknikler geçerli ilişkilere bağlandı mı? CTI entegrasyon zinciri tamamlandı mı? Koşum güncel olay içeriyor mu? Skorun yanında üretilen graf sonuçların kökenini, bütünlük kapısı ise veri paketinin yayımlanabilir olup olmadığını gösterir.

II. İLGİLİ ÇALIŞMALAR VE ARAŞTIRMA BOŞLUĞU

A. SOC, SIEM ve Olgunluk Değerlendirmesi

SOC literatürü güvenlik operasyonlarının yalnız teknoloji seçimine indirgenemeyeceğini; organizasyon, iş akışları, analist yükü ve ölçüm problemlerinin birlikte ele alınması gerektiğini göstermektedir [1]–[3]. SOC-CMM bu yaklaşımı olgunluk değerlendirmesine dönüştürür [8]. Manzoor ve arkadaşları ise Wazuh dâhil açık kaynak SIEM çözümlerini güvenlik özellikleri ve performans bakımından karşılaştırmıştır [4]. SACI insan ve süreç olgunluğunu ya da ürün performansını değil, belirli bir SIEM kurulumunda tanımlanmış teknik kanıt beklentilerinin gerçekleşip gerçekleşmediğini ölçer.

B. ATT&CK Tabanlı Görünürlük ve Tespit Kapsamı

DeTT&CT veri kaynağı kalitesi, görünürlük, tespit kapsamı ve tehdit aktörü davranışlarını ATT&CK üzerinde karşılaştırmak için kullanılan önemli bir pratik tabandır [5]. Chamkar ve arkadaşları düşük seviyeli olay ve örüntüleri ATT&CK tekniklerine bağlayarak use-case kapsamını değerlendirmiştir [6]. SACI'nin ayrıldığı nokta, teknik puanını tek başına üretmemesi; teknik kapanışını belirli varlık, log kaynağı, etkin kontrol, kural ve gözlenen alarm ilişkisine bağlamasıdır. Ayrıca veri paketinin yapısal geçerliliği kapsam skorundan bağımsız bir kararla denetlenir. Bu tercih ATT&CK kapsamının tespit etkinliği olarak yorumlanmasına yönelik ampirik eleştirilerle uyumludur [7].

C. CTI ve Kanıt Grafları

Mavroeidis ve Bromander CTI taksonomileri, paylaşım standartları ve ontolojileri arasındaki parçalanmayı incelemiştir [10]. Griffioen ve arkadaşları CTI beslemelerinin zamanlılık, duyarlılık, özgünlük ve etki bakımından farklı kalite özellikleri taşıdığını göstermiştir [11]. MISP işbirlikçi paylaşım ve gösterge yönetimi için uygulanmış bir platform sunar [12]. SACI'nin CTIC bileşeni bu kalite boyutlarını ölçmez; Wazuh-MISP hattındaki sorgu, eşleşme, alarm ve ATT&CK bağlamı adımlarının test kapsamında kapanıp kapanmadığını ölçer.

KRYSTAL, bilgi grafiği tehdit tespiti, saldırı grafiği ve senaryo yeniden oluşturma için kullanır [9]. Hogan ve arkadaşları bilgi graflarında şema, kimlik, kalite değerlendirmesi ve yayınlama adımlarının güvenilir veri yönetimi için temel olduğunu vurgular [13]. SACI grafiği ise çıkarım veya saldırı yolu keşfi yapmak yerine skorun hangi ilişki satırlarından üretildiğini göstermeye ve referans bütünlüğünü denetlemeye hizmet eder. Tablo I konumlandırmayı özetlemektedir.

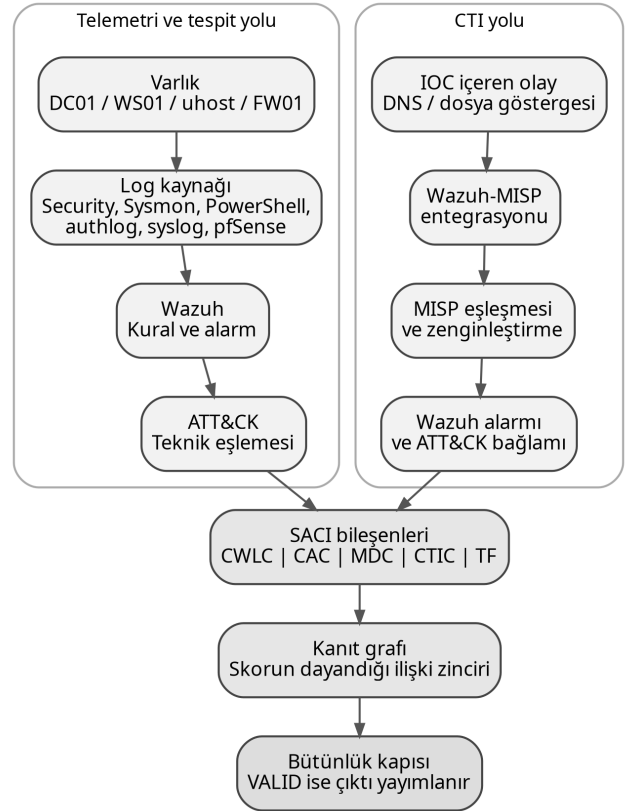
III. SACI YÖNTEMİ

A. Uçtan Uca Kanıt Zinciri

SACI'nin işleyişi iki temsili yol üzerinden açıklanabilir. İlk yolda DC01 üzerinde hesap veya ağ keşfi davranışı üretilir. Windows Security ya da Sysmon olayı Wazuh tarafından alınır, özel tespit kuralı alarm üretir ve kural kapsamı içindeki ATT&CK tekniğine bağlanır. Böylece aynı gözlem log kapsamına, kontrol kapsamına ve teknik kapsamına kanıt sağlar. İkinci yolda sentetik IOC içeren DNS veya dosya olayı Wazuh-MISP entegrasyonuna iletilir. MISP eşleşmesi zenginleştirme

TABLO I
SACI'NIN YAKIN YAKLAŞIMLARLA KONUMU

Yaklaşım	Ana odak	Kanıt zinciri	CTI	Bütünlük kapısı
SOC-CMM	SOC olgunluğu	Hayır	Hayır	Hayır
DeTT&CT	Veri kaynağı ve ATT&CK kapsamı	Kısmi	Hayır	Hayır
Chamkar vd.	Use-case ve ATT&CK boşlukları	Kısmi	Hayır	Hayır
KRYSTAL	Saldırı keşfi ve yeniden oluşturma	Var	Var	Farklı amaç
SACI	Sabit kapsamlı SIEM-C kanıt kapanışı	Var	Var	Var



Şekil 1. Telemetri/tespit ve CTI kanıt yollarının SACI bileşenleriyle ilişkisi.

kaydına, Wazuh alarmına ve ATT&CK bağlamına dönüştürülür. Şekil 1 iki yolu ve yayın kararını göstermektedir.

B. Kapsam ve Graf Şeması

Değerlendirme başlamadan önce varlıklar, her varlıktan beklenen log kaynakları, uygulanabilir kontroller, kapsam içindeki ATT&CK teknikleri ve IOC test kayıtları sürümlü veri dosyalarında tanımlanır. Bu tanım paydadır. Kapsamdan çıkarılan her öge gerekçe ve sürüm bilgisi taşır; farklı kapsam kimliklerine sahip koşumlar doğrudan karşılaştırılmaz. Etkin olması gereken ancak gözlenmeyen kontrol boşluk olarak kalır. Gerçekten uygulanabilir olmayan veya emekliye ayrılması

kontrol yalnız belgelenmiş politika gerekçesiyle paydadan çıkarılır.

Graf $G = (V, E)$ biçimindedir. V ; varlık, log kaynağı, kontrol, Wazuh kuralı, ATT&CK tekniği, IOC, entegrasyon ve metrik düğümlerinden oluşur. E kümesi yönlü ilişkiler içerir. Her ilişki gözlem durumu, kanıt kaynağı ve gerektiğinde benzersiz `evidence_id` alanı taşır. Graf bağımsız bir doğrulama veri kümesi değil, skor tablosundaki iddiaların köken görünümüdür.

Teknik kimlikleri Enterprise ATT&CK matrisinden, CTI nesne semantiği ise STIX 2.1 standardından alınmıştır [14], [15]. Ölçülerin amaç, kapsam, veri kaynağı, hesaplama yöntemi ve yorum sınırıyla birlikte tanımlanması; NIST sürekli izleme ve bilgi güvenliği ölçüm kılavuzları ile ISO/IEC 27004 ölçüm yaklaşımıyla uyumludur [16]–[19]. Bu operasyonelleştirme, sistem güvenliği metriklerinin açık tanım, kapsam ve yorumlanabilirlik sorunlarını ele alan literatürle de uyumludur [20]. Bu kaynaklar SACI ağırlıklarını belirlemez; ağırlıklar deney kapsamında açıkça tanımlanan tasarım parametreleridir.

C. Bileşenler ve Birleşik Skor

Bileşen skorlarının tümü 0–100 aralığındadır. A varlık kümesini, L_a varlık a için beklenen log kaynaklarını, c_a varlık kritikliğini, w_{as} kaynak ağırlığını ve o_{as} gözlem durumunu gösterir:

$$v_a = \frac{\sum_{s \in L_a} w_{as} o_{as}}{\sum_{s \in L_a} w_{as}}, \quad (1)$$

$$CWLC = 100 \frac{\sum_{a \in A} c_a v_a}{\sum_{a \in A} c_a}. \quad (2)$$

Kontrol/alarm kapsamı (CAC), yalnız uygulanabilir ve etkin kontrol kümesi C^* üzerinde hesaplanır. u_c kontrol ağırlığını, g_c ise geçerli alarm veya kanıt görülme durumunu gösterir:

$$CAC = 100 \frac{\sum_{c \in C^*} u_c g_c}{\sum_{c \in C^*} u_c}. \quad (3)$$

MDC, önceden belirlenen T_{scope} teknik kümesinde en az bir geçerli tespit zinciriyle kapanan tekniklerin oranıdır:

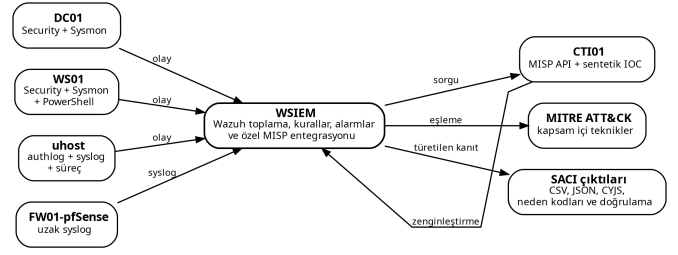
$$MDC = 100 \frac{\sum_{t \in T_{scope}} z_t}{|T_{scope}|}. \quad (4)$$

CTIC, her sentetik IOC için sorgu adımı q_i , MISP eşleşmesi h_i , Wazuh alarmı a_i ve ATT&CK bağlamı m_i olmak üzere dört iş akışı adımını sayar:

$$CTIC = 100 \frac{\sum_{i \in I} (q_i + h_i + a_i + m_i)}{4|I|}. \quad (5)$$

Mevcut prototipte q_i bağımsız HTTP istek–cevap kaydından değil senaryo beklentisinden başlatılmaktadır. Bu nedenle CTIC, CTI kalitesi veya tam sorgu kökeni değil, yapılandırılmış entegrasyon iş akışının kapanışıdır. TF ise skor zamanı ile koşumdaki en yeni olay arasındaki yaşa göre 100, 80, 50 veya 0 değerini alır; kaynak bazında sağlık ölçümü değildir.

Nihai skor, normalize edilmiş bileşenleri basit toplamsal ağırlıklandırma (Simple Additive Weighting, SAW) mantığıyla birleştirir [21]. Bu deneyde ağırlıklar CWLC=0,30, CAC=0,25,



Şekil 2. Wazuh-MISP laboratuvarındaki varlıklar ve veri akışları.

MDC=0,20, CTIC=0,15 ve TF=0,10 olarak belirlenmiştir. M^* aktif bileşen kümesi ve α_j bileşen ağırlığıdır:

$$SACI = \frac{\sum_{j \in M^*} \alpha_j M_j}{\sum_{j \in M^*} \alpha_j}. \quad (6)$$

Ağırlıklar evrensel veya istatistiksel olarak öğrenilmiş değerler değildir; laboratuvarın önceden açıklanmış öncelikleridir. Zorunlu veri dosyası eksikse, payda sıfır ya da aktif bileşen kümesi boşsa sonuç yayımlanmaz.

D. Bütünlük Kapısı ve Neden Kodları

Skor hesaplaması ile veri bütünlüğü ayrı sonuçlardır. Doğrulamayı düğüm kimliği benzersizliğini, zorunlu sütunları, kaynak ve hedef uçların düğüm envanterinde bulunmasını, doğru-ATT&CK eşlemelerinin tutarlılığını, paralel ilişkilerde `evidence_id` benzersizliğini ve CSV–CYJS eşleşmesini denetler. Bu kontrol yaklaşımı, bilgi graflarında şema, kimlik ve kalite doğrulamasını yayınlama sürecinin ayrı bir parçası olarak ele alan genel ilkeleri uygulama grafına uyarlamaktadır [13]. Zorunlu bir kural ihlal edildiğinde çıktı INVALID veya INCOMPLETE olur; yayın kapısı açılmaz. Kapanmayan bileşenler neden kodlarıyla raporlanır.

IV. DENEY ORTAMI VE UYGULAMA

A. Laboratuvar Topolojisi

Kontrollü laboratuvar altı mantıksal varlıktan oluşmaktadır. WSIEM merkezi Wazuh toplama ve kural değerlendirme katmanıdır. DC01 ve WS01 Windows olaylarını, uhost Linux günlüklerini, FW01-pfSense ağ olaylarını, CTI01 ise MISP API ve sentetik IOC kayıtlarını sağlar. Windows kanalları ve Linux günlükleri Wazuh toplama yapılandırmalarıyla, pfSense olayları uzak syslog ile aktarılmıştır [22]–[25]. Şekil 2 veri yollarını göstermektedir.

B. Kontrollü Davranışlar ve Veri Toplama

Windows/DC01 yolu Ansible ve WinRM ile çalışan zararsız bir senaryo çalıştırıcısıyla sınanmıştır. Hesap ve etki alanı keşfi, ağ ve paylaşım keşfi, DNS IOC sorgusu ve yerel Python HTTP sunucusundan zararsız dosya aktarımı davranışları üretilmiştir. Her komut senaryo, beklenen ATT&CK tekniği, kural kimliği ve dönüş koduyla JSONL biçiminde kaydedilmiş; ardından Wazuh alarm dosyasında ilgili kurallar aranmıştır. Linux, pfSense ve CTI yolları için kapsam ve alarm kanıtları

TABLO II
DENEYDE ÜRETİLEN TEMSİLİ DAVRANIŞLAR

Davranış	Üretilen kanıt	İlgili kapsam
Hesap / etki alanı keşfi	Security ve Sysmon olayları	CWLC, CAC, MDC
Ağ ve paylaşım keşfi	Komut, süreç ve erişim olayları	CWLC, CAC, MDC
Zararsız dosya aktarım	HTTP aktarımı ve uç olayları	CAC, MDC
Sentetik IOC sorgusu	DNS/dosya olayı, MISP kaydı, al	CTIC

kullanılmış, ancak bu yolları baştan kuran eşdeğer saldırı çalıştırıcıları yayımlanmamıştır.

Skorlayıcı Wazuh alarmlarını, MISP zenginleştirme kayıtlarını, senaryo olaylarını ve pfSense kanıtını normalize eder. Varlık ve log ilişkisi agent adı/kimliği, sağlayıcı, kanal, olay konumu, kural kimliği ve ATT&CK metaverisiyle kurulur. Aynı normalize tablolarından bileşen skorları ve graf çıktıları türetilir. Araştırma paketi kapsam tablolarını, skor sonuçlarını, graf dosyalarını, neden kodlarını ve doğrulayıcıyı yayımlar [26].

C. Değerlendirme Düzeni

Değerlendirme üç parçadan oluşmaktadır. Birinci parça tüm tanımlı beklentilerin gözlemlendiği kanonik koşumdur. İkinci parçada kritik ve kritik olmayan telemetri, CTI ve tazelik girdileri kaldırılarak skorun beklenen yönde değişip değişmediği incelenmiştir. Bu senaryolar istatistiksel örneklem değil, formül ve kapsam politikasına yönelik deterministik arıza testleridir. Üçüncü parçada eksik uç, çelişkili eşleme, yinelenen düğüm kimliği ve paralel kanıt çakışması gibi kusurlar enjekte edilerek bütünlük kapısının kararı sınanmıştır.

V. SONUÇLAR

A. Kanonik Kapsam Sonucu

Kanonik koşumda altı varlık için tanımlanan 12 varlık-log çiftinin tamamı gözlenmiştir. Emekliye ayrılmış iki legacy kontrol kapsam politikasıyla hariç tutulmuş; kalan 25 etkin kontrolün tamamı geçerli alarm veya kanıt üretmiştir. Kapsam içindeki 13 ATT&CK tekniği en az bir geçerli tespit zinciriyle kapanmış, iki IOC için dört adımlı CTI iş akışı 8/8 olarak tamamlanmıştır. Koşum tazeliği eşiği de sağlanmıştır.

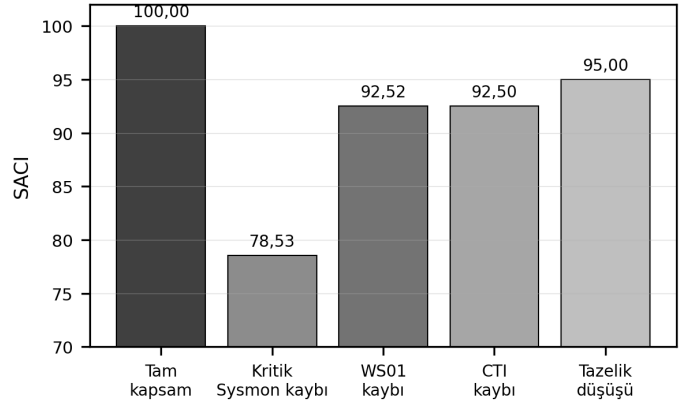
Sonuç SACI=100'dür. Bu değer laboratuvarın güvenli olduğunu ya da bütün saldırıların algılanacağını göstermez; yalnız tanımlı kapsamın uygulanan gözlem kuralları altında kapandığını gösterir. Birleşik değer bu nedenle her zaman bileşen vektörü, kapsam kimliği ve bütünlük kararıyla birlikte okunmalıdır.

B. Duyarlılık Senaryoları

Şekil 3 seçili arıza senaryolarını göstermektedir. Kritik DC01 Sysmon kaybı skoru 78,53'e düşürmüştü, kritik olmayan WS01 kaybı 92,52 üretmiştir. CTI iş akışındaki kayıp 92,50, koşum tazeliğinin gerilemesi ise 95,00 sonucunu vermiştir. Bu sonuçlar kritik varlık ağırlığının ve bileşen ağırlıklarının hesaplamaya

TABLO III
KANONİK SACI SONUÇLARI

Bileşen	Sonuç	Dayanak
CWLC	100,0	12/12 varlık-log çifti
CAC	100,0	25/25 etkin kontrol
MDC	100,0	13/13 kapsam içi teknik
CTIC	100,0	2 IOC x 4 adım = 8/8
TF	100,0	Koşumun en yeni olayı <= 60 dk
SACI	100,0	Ağırlıklı bileşen toplamı



Şekil 3. Seçili kanıt kayıplarında SACI değerinin değişimi.

beklendiği gibi yansıdığını gösterir; gerçek tespit olasılığı veya nedensel etki büyüklüğü göstermez.

C. Bütünlük Kapısı

Bütünlük denetimi skor ile graf geçerliliğinin neden ayrı tutulduğunu göstermiştir. Ön yayın paketinde SACI=100 ve bütün ilişki satırları observed=1 olmasına karşın iki ilişki ucu düğüm envanterinde yoktu ve bir kuralın doğrudan ATT&CK eşlemesi CTI bağlamıyla karışmıştı. Bu paket INVALID olarak değerlendirilmiştir. Eksik düğümler eklenmiş, doğrudan eşleme ile bağlamsal ilişki ayrılmış ve paralel kanıtlar benzersiz evidence_id değerleriyle tanımlanmıştır. Düzeltilen kanonik graf 99 düğüm, 171 ilişki satırı ve sıfır etkin bütünlük bulgusuyla VALID durumuna geçmiştir.

Dokuz kontrollü kusur vakasının her biri beklenen VALID, INVALID veya INCOMPLETE sınıfını üretmiştir. Bu test, bütünlük kapısının yalnız ilk bulunan hataya özel bir düzeltme olmadığını; farklı referans ve şema bozulmalarını ayırtabildiğini göstermektedir.

VI. TARTIŞMA

A. Mevcut Yaklaşımlara Eklenen Değer

SACI'nin yeniliği ATT&CK tekniği saymak veya siber güvenlik verisini ilk kez grafa dönüştürmek değildir. DeTT&CT görünürlük ve tespit kapsamı için daha olgun bir operasyonel taban, Chamkar ve arkadaşlarının yöntemi ise use-case boşluk

TABLO IV
TEMSİLİ BÜTÜNLÜK KURALLARI

Kusur	Karar	Neden
Beyan edilmemiş uç	INVALID	İlişki düğüm envanterine bağlanmıyor
Çelişkili ATT&CK eşlemesi	INVALID	Doğrudan tespit ile bağlam karışıyor
Aynı evidence_id ile paralel ilişki	INVALID	Kanıt örnekleri ayırt edilemiyor
Politikayla açıklanmış izole düğüm	VALID	İstisna gerekçesi kayıtlı

analizi için doğrudan bir akademik karşılaştırma sunar [5], [6]. SACI'nin katkısı bu kapsama varlık düzeyindeki beklenen log çiftlerini, Wazuh kontrol ve kural gözlemlerini, CTI entegrasyon adımlarını ve fail-closed bütünlük kararını eklemektir. Böylece covered=1 değeri yalnız teknik etiketine değil, denetlenebilir ilişki zincirine dayanır.

Graf katmanı da saldırı keşfi yapan KRYSTAL gibi sistemlerle aynı amaçta değildir [9]. SACI grafi skorun nedenini takip etmeyi ve veri paketi içindeki tutarsızlıkları bulmayı sağlar. Yöntemin uygun kullanım alanları yeni log kaynağı devreye alma kontrolü, sabit kapsamlı görünürlük zaman serisi, denetim öncesi kanıt tamlığı incelemesi ve laboratuvar senaryolarının kapanış kontrolüdür. Farklı kurum veya ürünleri tek SACI değeriyle sıralamak, kapsam ve ağırlıklar kalibre edilmeden savunulamaz.

B. Geçerlik Sınırları

İlk sınırlama kapsamın önceden tanımlanmasıdır. SACI envantere bulunmayan varlığı veya seçilmemiş tekniği kendiliğinden keşfetmez. Kapsam daraltılırsa skor yükselebileceği için varlık, kontrol ve teknik paydaları kurumsal envanter veya tehdit modeliyle doğrulanmalı; her çıkarma sürümlemiş gerekçeyle kaydedilmelidir.

İkinci sınırlama TF ve CTIC bileşenleridir. TF bütün kaynakların en yeni tek olayını kullandığından taze bir kaynak eski akışları maskeleyebilir. Üretim sürümünde tazelik her varlık-log çifti için ayrı hesaplanmalıdır. CTIC içindeki lookup adımı bağımsız istek-cevap kaydına dayanmadığı için sonuç CTI besleme kalitesi veya tam sorgu kökeni olarak yorumlanmamalıdır. Griffioen ve arkadaşlarının ölçtüğü CTI kalite boyutları bu çalışmanın dışında kalmaktadır [11].

Üçüncü sınırlama dış geçerliktir. Deney tek bir altı varlıklı Wazuh-MISP laboratuvarı, iki sentetik IOC ve 13 seçili teknik yapılmıştır. Duyarlılık senaryoları kodun tanımlı girdilere tepki verdiğini gösterir; yanlış pozitif/negatif oranı, MTTD veya gerçek saldırı tespit başarısı hakkında sonuç üretmez. Bu sorular için farklı SIEM ürünlerinde, gerçek olay kimlikleri ve tekrarlı saha koşullarıyla ek doğrulama gereklidir.

C. Yeniden Üretilebilirlik

Yayımlanan paket pay ve paydaların yeniden hesaplanmasına, grafin incelenmesine ve bütünlük kurallarının çalıştırılmasına

olanak verir [26]. Güvenlik araştırmalarında deney adımlarının, veri kaynaklarının ve artefaktların açıkça belgelenmesi ihtiyatlı araştırma uygulaması olarak önerilmektedir [27]. Aynı girdiler ve analiz adımlarıyla sonuçların yeniden hesaplanması ile bağımsız bir ortamda deneyin yeniden kurulması farklı güvence düzeyleridir [28]. Buna karşılık özgün ürün sürümleri, tüm Sysmon ve Wazuh yapılandırmaları, kimlik bilgileri ve ham canlı log anlık görüntüsü eksiksiz olarak korunmamıştır. Bu nedenle çalışma sonuç ve artefakt denetimini destekler; özgün laboratuvarın tam dijital ikizini sağlamaz.

VII. SONUÇ

Bu çalışmada SIEM görünürlüğünü varlık, log kaynağı, etkin kontrol, Wazuh kuralı, ATT&CK tekniği ve CTI iş akışı arasındaki gözlenen ilişkiler üzerinden ölçen SACI sunulmuştur. Altı varlıklı laboratuvarda kanonik kapsam kapanmış, seçili telemetri ve CTI kayıpları ilgili bileşenleri düşürmüş, bütünlük kapısı ise sayısal sonuç tam görünse dahi yapısal olarak bozuk çıktıları engellemiştir.

SACI'nin temel çıktısı tek bir 0–100 değeri değildir. Bileşen vektörü, kapsam sürümü, kanıt grafi, neden kodları ve VALID/INVALID kararı birlikte değerlendirilmelidir. Gelecek çalışma kaynak bazlı tazelik, gerçek CTI istek-cevap kökeni, kapsam dışı varlık keşfi ve farklı SIEM ortamlarında tekrarlı saha doğrulamasına odaklanacaktır.

VERİ VE ARAŞTIRMA PAKETİ

Kapsam ve skor tabloları, düğüm/ilişki dosyaları, neden kodları, bütünlük politikası, doğrulayıcılar ve senaryo serisi SACI Final Evidence Portal üzerinden yayımlanmıştır [26].

KAYNAKLAR

- [1] M. Vielberth, F. Böhm, I. Fichtinger, and G. Pernul, "Security operations center: A systematic study and open challenges," *IEEE Access*, vol. 8, pp. 227 756–227 779, 2020.
- [2] E. Agyepong, Y. Cherdantseva, P. Reinecke, and P. Burnap, "Challenges and performance metrics for security operations center analysts: A systematic review," *Journal of Cyber Security Technology*, vol. 4, pp. 125–152, 2020.
- [3] S. C. Sundaramurthy, J. Case, T. Truong, L. Zomlot, and M. Hoffmann, "A tale of three security operation centers," in *Proceedings of the ACM Workshop on Security Information Workers*, 2014, pp. 43–50.
- [4] J. Manzoor, A. Waleed, A. F. Jamali, and A. Masood, "Cybersecurity on a budget: Evaluating security and performance of open-source siem solutions for smes," *PLOS ONE*, vol. 19, no. 3, p. e0301183, 2024.
- [5] M. Bakker and R. Bouman, "Dett&ct: Detect tactics, techniques and combat threats," Open-source software, Rabobank, 2026, accessed: 2026-07-13. [Online]. Available: <https://github.com/rabobank-cdc/DeTTECT>
- [6] S. A. Chamkar, Y. Maleh, and N. Gherabi, "Security operations centers: Use case best practices, coverage, and gap analysis based on mitre adversarial tactics, techniques, and common knowledge," *Journal of Cybersecurity and Privacy*, vol. 4, no. 4, pp. 777–793, 2024.
- [7] A. Virkud, M. A. Inam, A. Riddle, J. Liu, G. Wang, and A. Bates, "How does endpoint detection use the mitre att&ck framework?" in *33rd USENIX Security Symposium*, 2024, pp. 3891–3909.
- [8] SOC-CMM, "Security operations center capability and maturity model," 2026, accessed: 2026-07-13. [Online]. Available: <https://www.soc-cmm.com/>
- [9] K. Kurniawan, A. Ekelhart, E. Kiesling, G. Quirchmayr, and A. M. Tjoa, "Krystal: Knowledge graph-based framework for tactical attack discovery in audit data," *Computers & Security*, vol. 121, p. 102828, 2022.
- [10] V. Mavrodis and S. Bromander, "Cyber threat intelligence model: An evaluation of taxonomies, sharing standards, and ontologies within cyber threat intelligence," in *European Intelligence and Security Informatics Conference*, 2017, pp. 91–98.

- [11] H. Griffioen, T. Bootj, and C. Doerr, "Quality evaluation of cyber threat intelligence feeds," in *Applied Cryptography and Network Security*, 2020.
- [12] C. Wagner, A. Dulaunoy, G. Wagener, and A. Iklody, "Misp: The design and implementation of a collaborative threat intelligence sharing platform," in *Proceedings of the 3rd ACM Workshop on Information Sharing and Collaborative Security*, 2016, pp. 49–56.
- [13] A. Hogan *et al.*, "Knowledge graphs," *ACM Computing Surveys*, vol. 54, no. 4, pp. 1–37, 2021.
- [14] The MITRE Corporation, "Enterprise att&ck matrix," 2026, accessed: 2026-07-13. [Online]. Available: <https://attack.mitre.org/matrices/enterprise/>
- [15] OASIS Cyber Threat Intelligence Technical Committee, "Stix version 2.1," OASIS Standard, 2021.
- [16] K. Dempsey, N. Chawla, A. Johnson, R. Johnston, A. Jones, A. Orebaugh, M. Scholl, and K. Stine, "Information security continuous monitoring for federal information systems and organizations," National Institute of Standards and Technology, Tech. Rep. NIST SP 800-137, 2011.
- [17] K. Schroeder, H. Trinh, and V. Pillitteri, "Measurement guide for information security: Volume 1—identifying and selecting measures," National Institute of Standards and Technology, Tech. Rep. NIST SP 800-55 Vol. 1, 2024.
- [18] —, "Measurement guide for information security: Volume 2—developing an information security measurement program," National Institute of Standards and Technology, Tech. Rep. NIST SP 800-55 Vol. 2, 2024.
- [19] ISO/IEC, "Iso/iec 27004:2016—information security management—monitoring, measurement, analysis and evaluation," International standard, 2016.
- [20] M. Pendleton, R. Garcia-Lebron, J.-H. Cho, and S. Xu, "A survey on systems security metrics," *ACM Computing Surveys*, vol. 49, no. 4, pp. 1–35, 2016.
- [21] E. Triantaphyllou, *Multi-Criteria Decision Making Methods: A Comparative Study*. Boston, MA: Springer, 2000.
- [22] Wazuh, "Configuring log collection for different operating systems," 2026, accessed: 2026-07-13. [Online]. Available: <https://documentation.wazuh.com/current/user-manual/capabilities/log-data-collection/configuration.html>
- [23] —, "External api integration," 2026, accessed: 2026-07-13. [Online]. Available: <https://documentation.wazuh.com/current/user-manual/manager/integration-with-external-apis.html>
- [24] M. Russinovich and T. Garnier, "Sysmon," 2026, accessed: 2026-07-13. [Online]. Available: <https://learn.microsoft.com/en-us/sysinternals/downloads/sysmon>
- [25] Netgate, "Remote logging with syslog," 2026, accessed: 2026-07-13. [Online]. Available: <https://docs.netgate.com/pfsense/en/latest/monitoring/logs/remote.html>
- [26] İ. Arslan, "Saci final evidence portal and source repository," Research artifact, 2026, accessed: 2026-07-13. [Online]. Available: <https://4rslanismet.github.io/saci-final-evidence/>
- [27] C. Rossow *et al.*, "Prudent practices for security research," in *2012 IEEE Symposium on Security and Privacy*, 2012, pp. 46–59.
- [28] National Academies of Sciences, Engineering, and Medicine, *Reproducibility and Replicability in Science*. Washington, DC: The National Academies Press, 2019.